

## 1. Alert Priority Levels:

### Overview:

In a Security Operations Center (SOC), alert prioritization is a critical process used to determine the urgency and impact of security incidents. Proper prioritization enables analysts to respond efficiently, reduce incident response time, and minimize business impact. Alerts are categorized into priority levels based on severity, exploitability, asset importance, and organizational risk.

### Priority Definitions:

Alert priority indicates the seriousness of an incident and the speed at which it must be handled.

| Priority Level  | Description                                                 | Example                                   |
|-----------------|-------------------------------------------------------------|-------------------------------------------|
| <b>Critical</b> | Active compromise with immediate and severe business impact | Ransomware encrypting a production server |
| <b>High</b>     | Confirmed malicious activity with high risk                 | Unauthorized administrator access         |
| <b>Medium</b>   | Suspicious behavior requiring investigation                 | Multiple failed login attempts            |
| <b>Low</b>      | Informational or expected activity                          | Internal vulnerability scan               |

### Alert Assignment Criteria:

SOC analysts assign alert priority using multiple contextual factors rather than relying solely on automated alerts.

#### 1. Asset Criticality

The importance of the affected asset to business operations:

- Production servers, databases, and domain controllers → Higher priority.
- Test systems and non-critical endpoints → Lower priority.

## 2. Exploit Likelihood

Evaluation of how likely an attack can be exploited:

- Publicly available exploit code.
- Active exploitation reported in threat intelligence feeds.

## 3. Business Impact

Assessment of potential consequences:

- Financial loss.
- Operational downtime.
- Data breach and compliance violations.

### Example:

Log4Shell vulnerability (CVE-2021-44228)

- CVSS Score: 9.8.
- Remote code execution on internet-facing systems.
- Actively exploited in the wild, classified as **Critical Priority**.

### Scoring Systems Used for Prioritization:

#### CVSS (Common Vulnerability Scoring System)

CVSS is a standardized framework used to quantify vulnerability severity. It consists of:

- **Base Metrics:** Intrinsic severity of the vulnerability.
- **Temporal Metrics:** Exploit maturity and remediation availability.

- **Environmental Metrics:** Asset value and business context.

### **SIEM Risk Scoring:**

Modern SIEM platforms such as **Splunk** use risk-based alerting by combining the following:

- Alert confidence.
- Asset criticality.
- User behavior analytics.
- Threat intelligence.

### **Incident Severity Classification:**

Incident prioritization and response workflows follow guidance from **NIST SP 800-61**, which defines best practices for:

- Incident categorization.
- Severity assignment.
- Escalation and response procedures.

### **Real-World Case Study: Log4Shell**

Security advisories published by **CISA** highlighted the critical nature of Log4Shell due to:

- Widespread impact.
- Remote exploitability.
- Availability of public exploits.

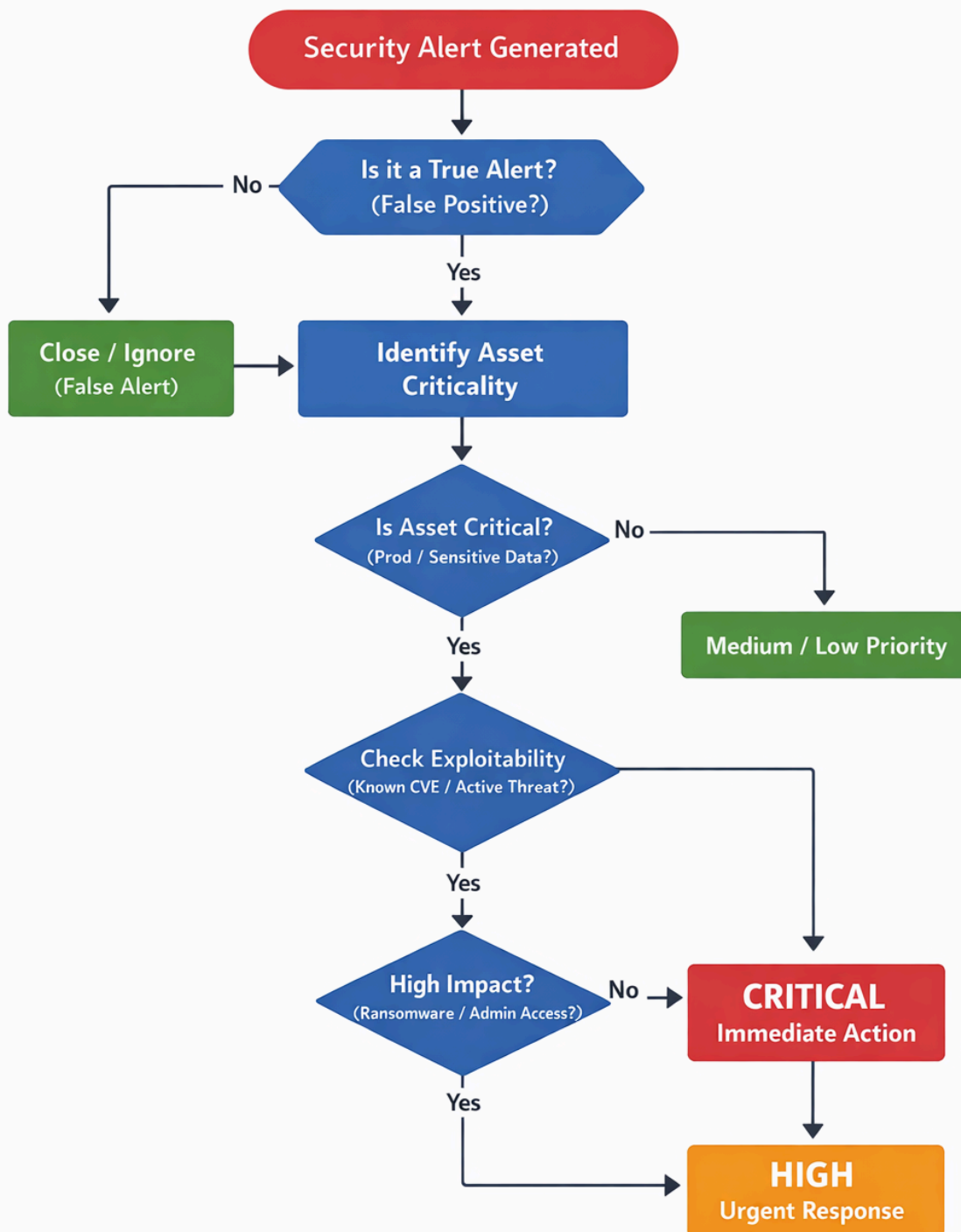
### **Learning Outcome:**

Through this study, the intern developed the ability to:

- Evaluate alerts using standardized criteria.
- Map CVSS scores to SOC priority levels.
- Incorporate business context into security decisions.
- Support efficient and justified incident response actions.

## **SOC Alert Priority Decision Flowchart:**

## SOC Alert Priority Decision Flowchart



## 2. Incident Classification:

### Overview:

Incident classification is the process of identifying and categorizing security events based on their nature, attack type, and impact. Proper classification helps Security Operations Center (SOC) analysts organize incidents, prioritize investigations, and apply appropriate response procedures. Standardized classification also improves communication between security teams and ensures consistent documentation across incidents.

### Incident Categories:

Security incidents are classified according to the type of threat or attack involved. Some common incident categories include:

| Incident Type                               | Description                                                                | Example                                                |
|---------------------------------------------|----------------------------------------------------------------------------|--------------------------------------------------------|
| <b>Malware</b>                              | Malicious software designed to disrupt systems or steal data               | Trojan detected on a workstation                       |
| <b>Phishing</b>                             | Fraudulent emails or messages used to steal credentials or install malware | Fake login page sent via email                         |
| <b>DDoS (Distributed Denial of Service)</b> | Attack that overwhelms systems or networks with traffic                    | Website outage due to massive botnet traffic           |
| <b>Insider Threat</b>                       | Malicious or negligent activity from internal users                        | Employee exporting sensitive company data              |
| <b>Data Exfiltration</b>                    | Unauthorized transfer of data outside the organization                     | Large volume of confidential files sent to external IP |

Correct classification allows SOC analysts to apply the appropriate investigation and response strategy.

### Incident Classification Frameworks:

To ensure consistent labeling and analysis, SOC teams rely on standardized security frameworks.

### **MITRE ATT&CK Framework:**

The **MITRE Corporation** developed the **MITRE ATT&CK** framework to document real-world adversary behavior.

It categorizes attacks into **tactics** (attacker goals) and **techniques** (methods used).

Example:

- **Tactic:** Initial Access
- **Technique:** Phishing – T1566

This mapping helps analysts understand how attackers gain entry and move through a network.

### **ENISA Incident Taxonomy:**

The **European Union Agency for Cybersecurity** provides a structured taxonomy for classifying cybersecurity incidents across organizations. It standardizes categories such as

- Malware infections
- Network attacks
- Data breaches
- Identity theft

This taxonomy improves communication between incident response teams and regulatory bodies.

### **VERIS Framework:**

The **VERIS** framework is used to document security incidents in a structured format.

VERIS focuses on four core elements:

- **Actor** – Who performed the attack.
- **Action** – What actions were taken.
- **Asset** – Which system was targeted.
- **Attribute** – Impact on confidentiality, integrity, or availability.

This framework is widely used for threat intelligence and breach reporting.

## **Contextual Metadata in Incident Analysis:**

In addition to classification, SOC analysts enrich incidents with contextual metadata to support investigations. Important metadata includes:

- **Affected systems** (servers, endpoints, databases).
- **Timestamp** of the incident.
- **Source and destination IP addresses.**
- **Indicators of Compromise (IOCs)** such as malicious file hashes or domains.
- **User accounts involved** in the incident.

This information helps analysts correlate alerts and identify the root cause of the attack.

## **Learning Outcome:**

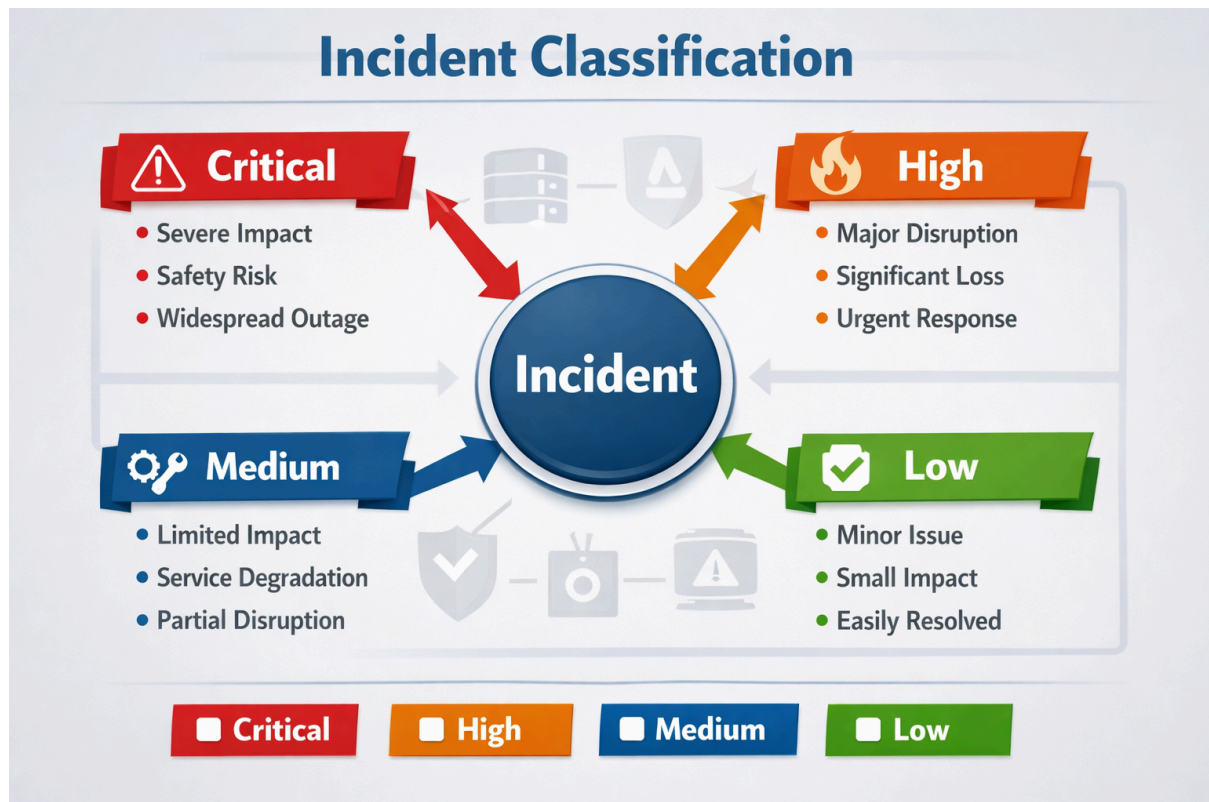
Through the study of incident classification methods, the intern developed the ability to:

- Categorize security incidents based on attack type.



- Map incidents to standardized frameworks such as MITRE ATT&CK.
- Enrich incidents with contextual metadata for effective investigation.
- Support structured documentation and reporting within SOC operations.

## Incident Classification Diagram:



## 3. Basic Incident Response:

### Overview

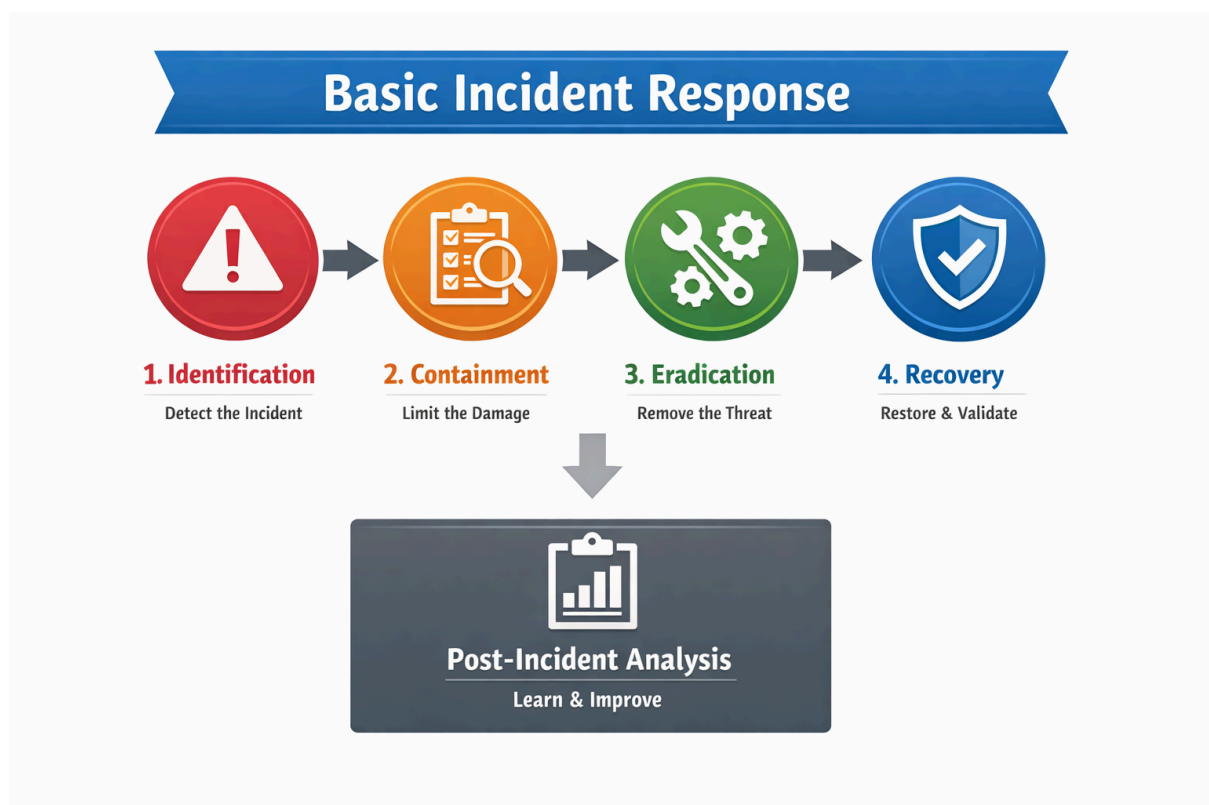
Incident Response (IR) is a structured approach used by Security Operations Center (SOC) teams to detect, manage, and recover from cybersecurity incidents. The goal of incident response is to minimize damage, reduce recovery time, and prevent similar incidents in the future. A well-defined response process ensures that security incidents are handled quickly and efficiently while preserving evidence for investigation.

### Incident Response Lifecycle

The incident response process follows a standardized lifecycle recommended by **NIST SP 800-61**. This lifecycle consists of six key phases:

| Phase                 | Description                                      | Example                                                |
|-----------------------|--------------------------------------------------|--------------------------------------------------------|
| <b>Identification</b> | Detect and analyze potential security incidents  | SIEM alert indicating suspicious login activity        |
| <b>Containment</b>    | Limit the spread and impact of the incident      | Isolating an infected workstation from the network     |
| <b>Eradication</b>    | Remove the root cause of the incident            | Deleting malware and closing exploited vulnerabilities |
| <b>Recovery</b>       | Restore systems and services to normal operation | Rebuilding compromised servers and restoring backups   |

This lifecycle helps organizations respond to incidents in a structured and repeatable manner.



## **Incident Response Procedures:**

SOC analysts follow specific procedures during an incident to ensure effective response and investigation.

### **System Isolation:**

Compromised systems are isolated from the network to prevent further spread of the attack.

Example actions include:

- Disconnecting affected machines from the network.
- Blocking malicious IP addresses.
- Disabling compromised user accounts.

### **Evidence Preservation:**

Maintaining digital evidence is essential for forensic analysis and legal compliance. Common evidence collection methods include:

- **Memory Dumps**—Capturing volatile memory for malware analysis.
- **File Hashing** – Generating cryptographic hashes (e.g., SHA-256) to verify file integrity.
- **Log Preservation** – Securing system and network logs for investigation.

### **Communication Protocols:**

During incident response, clear communication between teams is essential. This typically includes:

- Reporting incidents to security management.
- Coordinating with IT teams for containment and recovery.
- Documenting actions taken during the incident response process.

### **Automation Using SOAR Tools:**

Security teams increasingly use automation tools to accelerate incident response.

Platforms such as **Splunk Phantom** help automate tasks, including:

- Alert enrichment.
- Automated containment actions.
- Incident ticket generation.
- Workflow orchestration.

Automation reduces response time and improves consistency in handling incidents.

### **Learning Outcome:**

Through studying basic incident response processes, the intern gained the ability to:

- Understand the full incident response lifecycle.
- Identify and respond to security alerts effectively.
- Apply containment and eradication procedures.
- Preserve forensic evidence during investigations.
- Document incidents and improve future response strategies.